Task-3

API Security Risk Analysis Report

Prepared by: Sai Manikanta

Tools: Postman , Public APIs

Date: [18/4/2026]

Introduction:

This report presents a security analysis of publicly available APIs. The objective is to identify common security vulnerabilities such as lack of authentication, improper authentication, data exposure, and insufficient input validation.
The testing was conducted using safe and publickly available APIs for educational purpose.

Scope:

- Testing publicly accessible API endpoints such as **/users** and **/posts**
- Evaluating the presence of authentication and authorization mechanism.
- Observing API responses to identify potential security weakness.

Tools Used:

- Postman (API testing)
- Browser (for API access)
- Public APIs:jsonplaceholders.typicode.com

API Endpoints Tested:

- /users
- /users/{id}
- /posts
- /posts?userId=1

Security Findings

Finding 1: No Authentication

- Endpoint: /users
- Issue: The API allows access to user data without requiring authentication.

Description:
The endpoint can be accessed directly without login credentials or tokens.

Impact:
Unauthorized users can access sensitive user information.

Recommendation:
Implement authentication mechanisms such as JWT tokens or API keys.

Finding 2: Broken Authorization

- Endpoint: /users/{id}
- Issue: Users can access data of other users by modifying the ID.

Description:

By changing the user ID in the request, data of different users can be accessed without restrictions.

Impact:

Leads to unauthorized data access and privacy violations.

Recommendation:

Implement proper authorization checks to ensure users can only access their own data.

Finding 3: No Rate Limiting

- Issue: The API does not restrict the number of requests.

Description:

Multiple requests can be sent continuously without any limitation.

Impact:

This can lead to brute-force attacks and server overload.

Recommendation:

Implement rate limiting to restrict excessive API requests.

Finding 4: Sensitive Data Exposure

- Endpoint: /users
- Issue: Sensitive information such as email and phone numbers is exposed.

Description:

The API response includes personal user details without masking or protection.

Impact:

May lead to privacy issues and data misuse.

Recommendation:

Limit sensitive data exposure and apply data masking techniques

.

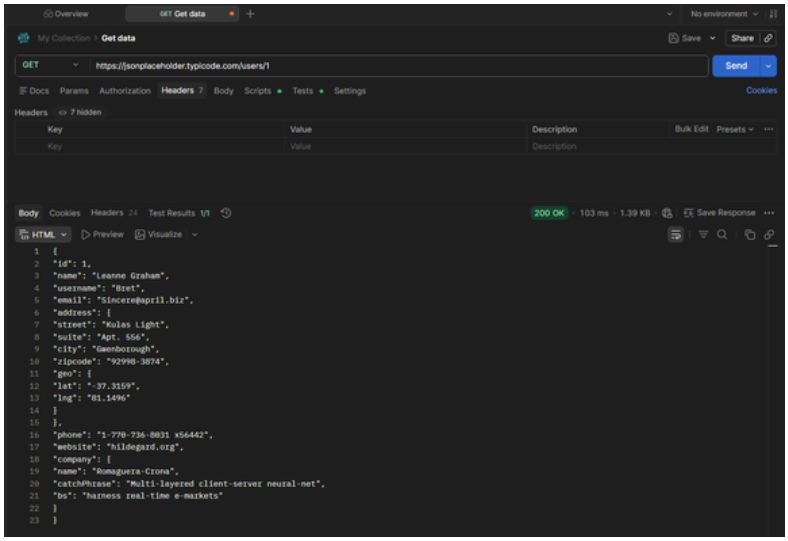
Finding 5: Lack of Input Validation

- Endpoint: /posts?userId=
- Issue: API accepts invalid or manipulated inputs.

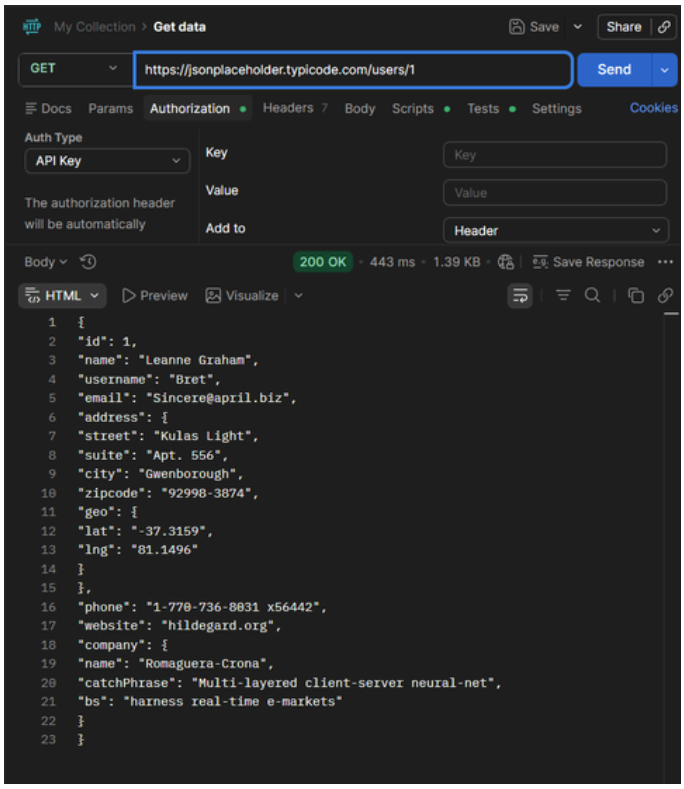
Description:
The API does not properly validate user input parameters.
Impact:
May lead to injection attacks or unexpected behavior.
Recommendation:
Validate and sanitize all user inputs before processing.

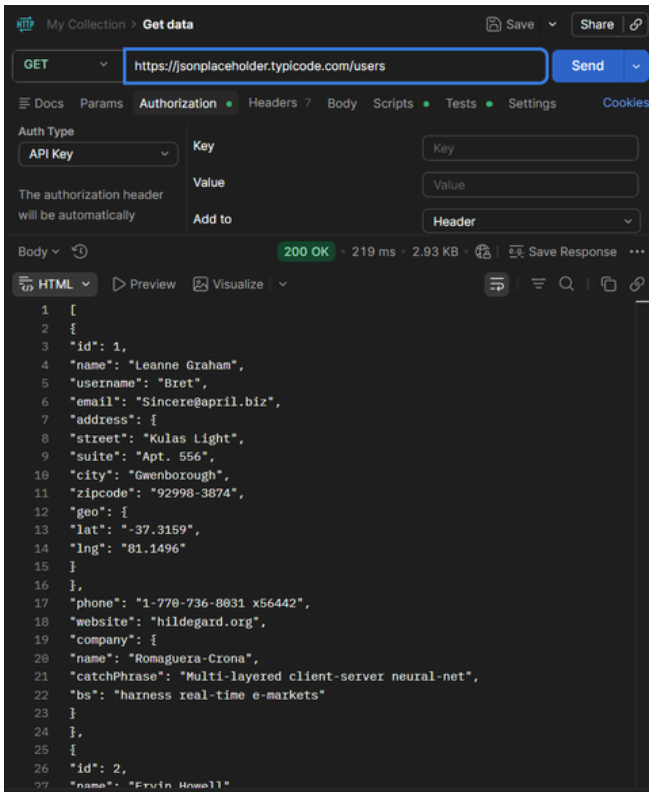
Proof (Screenshot):

1. No Authentication



2. Broken Authorization





Coclusion

The analysis shows that the tested API lacks essential security mechanisms such as authentication, authorization, and rate limiting. These vulnurabilities can lead to unauthorized access, data leaking, and potential system abuse.

Implementing proper security controls will significantly improve the overall security posture of the API